

Billy (BK) Rios » Firefoxurl URI Handler Flaw

Billy (BK) Rios » Firefoxurl URI Handler Flaw - Author not stated, xs-sniper.com.

- Published: date not stated
- Original: <<http://xs-sniper.com/blog/2007/07/17/firefoxurl-uri-handler-flaw/>>
- Preserved from: <http://xs-sniper.com/blog/2007/07/17/firefoxurl-uri-handler-flaw/> (stored) on 2026-08-06
- Capture timestamp: 20170113145707
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Top 10 Web Hacking Techniques lists, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

Billy (BK) Rios » Firefoxurl URI Handler Flaw

Tuesday, July 17th, 2007

Firefoxurl URI Handler Flaw

When certain versions of Firefox are installed, the Firefoxurl URI handler is registered in the Windows Registry. I'm sure everyone has seen the various **PoCs** where Internet Explorer basically forces Firefox to execute an arbitrary command using the Firefoxurl URI... its pretty cool. Although I reported this to Mozilla shortly before Thor released his **PoC** on his blog page, my research was based off his original Safari exploit, so I think he should get full credz for this one!

Now... a few people have asked me whether I consider this an IE flaw or a Firefox flaw... and the answer is BOTH. Problems with URI handlers will not be fixed until BOTH the browser (in this case, IE) and the registered application (in this case, FF) change how URI handlers are used. Before you start accusing me of fence sitting, let me explain my stance and maybe give you some insight as to why I feel this way.

- IE doesn't properly sanitize parameters passed to URI handlers. There are a lot of different exploits that can be pulled off because of this lack of sanitization... everyone knows about the Firefoxurl example, but did you know about **Netscape Navigator**, or **Trillian**? Bad IE...
- Firefox registers the URI handler in the Windows registry. None of this would even be possible if Firefox didn't register their URI handler. Know that when you register a URI handler in Windows, that URI can (and will) be remotely called by web pages through the browser (including IE). Maybe the Firefox devs should have known a little more about how URI handlers are called before they registered their URI on my machine. Bad Firefox...

This is just the tip of the iceberg... really. Some colleagues and I have been looking into URI handler vulnerabilities for quite some time now and I can tell you this.... IE isn't the only browser that has problems sanitizing parameters passed to URI handlers... remote command execution can be initiated from other browsers as well. To make matters worse, EVEN IF the browser did its job and sanitized malicious characters, URI handlers can still allow attackers to pass argument values to applications on YOUR system. If there are flaws in the software that registered the URI, you are still vulnerable (as evidenced by the [2nd Trillian exploit](#)). URI Handlers should be used with caution, browsers should sanitize, devs should understand the dangers of URI handlers before registering them, and anything dealing with URI handlers should be audited on a regular basis (as registering URI handlers greatly increases your attack surface)....more URI handler vulnerabilities to come... stay tuned. In the meantime, here's a whitepaper about various [URI uses and Abuses](#).

Posted by xssniper | Filed in [Security](#)

Please leave a Comment

Archived from <http://xs-sniper.com/blog/2007/07/17/firefoxurl-uri-handler-flaw/>. Rendered offline from the local Markdown copy.